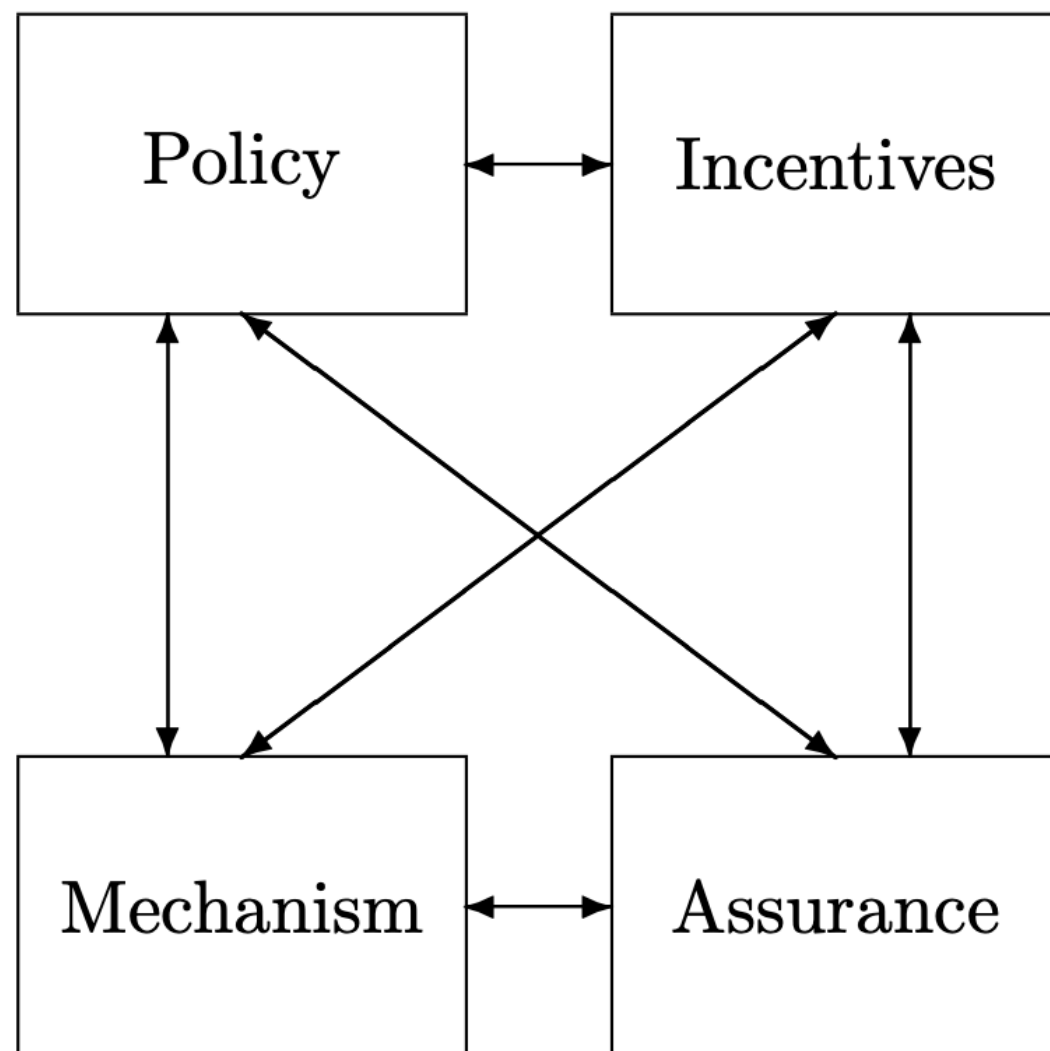


Privacidade e Protecção de Dados Pessoais

Mestrado em Direito e Informática
2019/2020

Hugo Pacheco
hpacheco@di.uminho.pt

Segurança



de **Security Engineering**,
Ross Anderson, 3rd Edition

- Política: o que se quer obter
- Mecanismo: como implementar a política
- Confiabilidade: quanta confiança se tem no mecanismo
- Incentivo: motivos dos “atacantes” ou “defensores”

Sistemas de Segurança

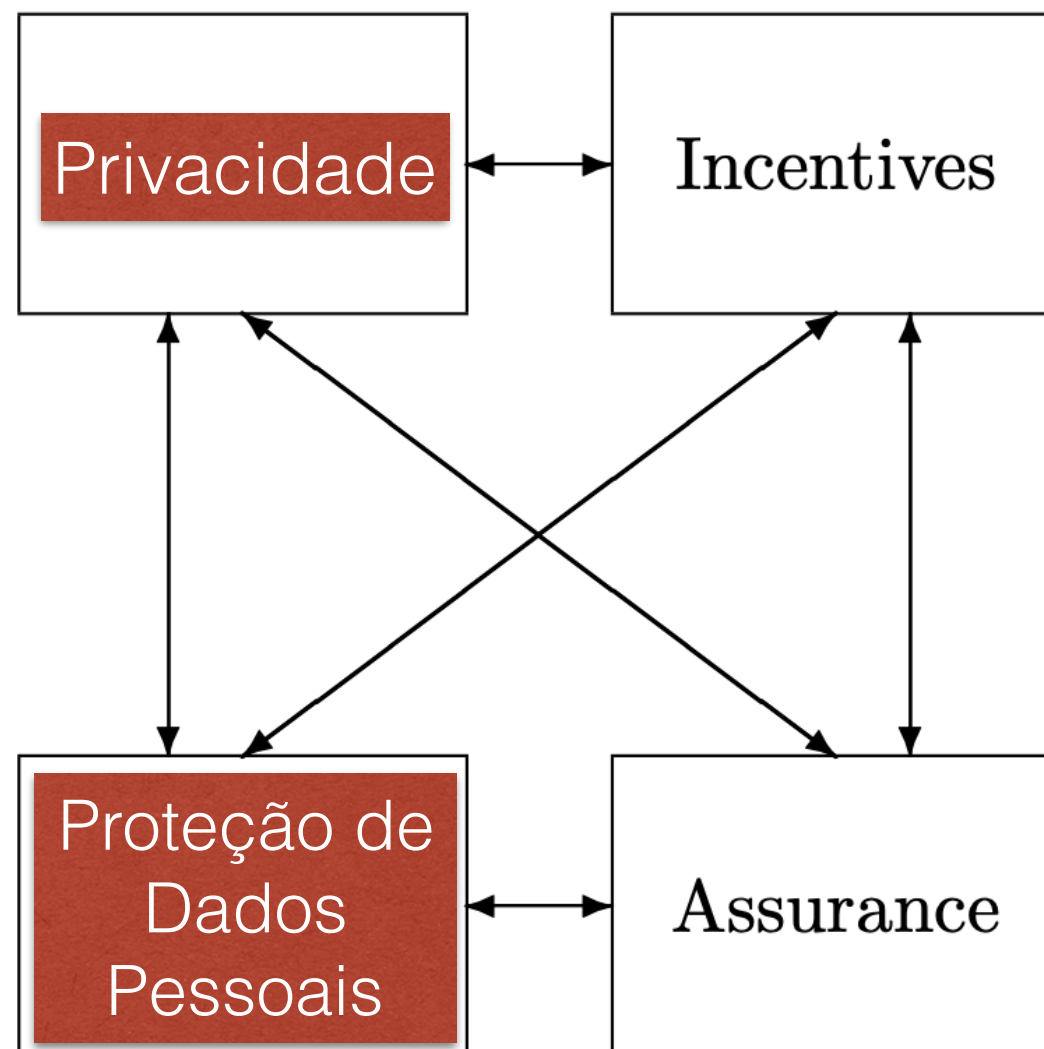
- *“Um terrorista consegue entrar com uma faca num avião”*
- De quem é a culpa?

Sistemas de Segurança

- Bancos, bases militares
- Hospitais
 - segurança/privacidade dos dados dos clientes
 - uma das maiores fontes de falhas de segurança (e.g. ataque ransomware WannaCry Maio 2017)
- Casa?
 - e-banking, smart devices
 - bombas de insulina, pacemakers
 - microfones, câmaras

Sistemas de Segurança

- Vivemos num mundo cada vez mais conectado



Definições de Privacidade

- Direito a ser deixado em paz...
- *Ninguém sofrerá intromissões arbitrárias na sua vida privada, na sua família, no seu domicílio ou na sua correspondência, nem ataques à sua honra e reputação. Contra tais intromissões ou ataques toda a pessoa tem direito a protecção da lei.*
(art. 12º; Declaração Universal dos Direitos Humanos)
- *The quality or state of being apart from company or observation; b) freedom from unauthorized intrusion*
(Merrian-Webster)
- *The right of individual to be protected against intrusion into his personal life or affairs, or those of his family, by direct physical or by publication of information*
(Calcutt committee, UK)

Aspectos da Privacidade

- **Privacidade da informação**

- recolha e manipulação de dados pessoais (e.g. registos médicos)

- Privacidade física

- protecção contra procedimentos invasivos (e.g. teste dna ou genético)

- Privacidade das comunicações

- Correspondência, telefones, emails, etc.

- Privacidade territorial

- limites à intrusão em ambientes domésticos (e.g. video-vigilância)

Privacidade da Informação

- Estabelecimento de regras que regulem a recolha, armazenamento e processamento de **dados pessoais**
- Informação referente a indivíduos não deve ser disponibilizada de forma indiscriminada a outros indivíduos ou organizações
- Um indivíduo deve manter um nível substancial de controlo sobre a informação que lhe diz respeito e utilização que lhe é dada.

Dados Pessoais

- *any information which are related to an identified or identifiable natural person*
(art. 4º; GPDR)
- como por exemplo: *name, identification number, location data, online identifier, telephone, credit card, personnel number, account data, number plate, appearance, customer number, address*

Cookies



WEBSITE
COOKIES

- Testemunhos de conexão
- Surgiram como um recurso tecnológico para ultrapassar uma limitação do protocolo HTTP
- Permitem armazenar informação no próprio browser (e.g. dados de forms; histórico de sítios visitados; etc.)
- São extensivamente usados por *third-party ad-services* para construção de perfis do utilizador
- São considerados dados pessoais?

Cookies

- Legislação Europeia é particularmente exigente sobre consentimento na utilização de cookies
- Os críticos argumentam que é impraticável <https://www.davidnaylor.co.uk/>

This website uses cookies

We use cookies to personalise content and ads, to provide social media features and to analyse our traffic. We also share information about your use of our site with our social media, advertising and analytics partners who may combine it with other information that you've provided to them or that they've collected from your use of their services. You consent to our cookies if you continue to use our website.

☒ Necessary ☐ Preferences ☐ Statistics ☐ Marketing Show details ▼

OK

This website needs some cookies and similar means to function.

If you permit us, we will use those means to collect data on your visits for aggregated statistics to improve our service.

Moreover, we use YouTube for showing videos, which will use cookies and similar means only if you decide to watch them.

Accept cookies for aggregated statistics

No thanks, only technically necessary cookies

More information

Dados Encriptados

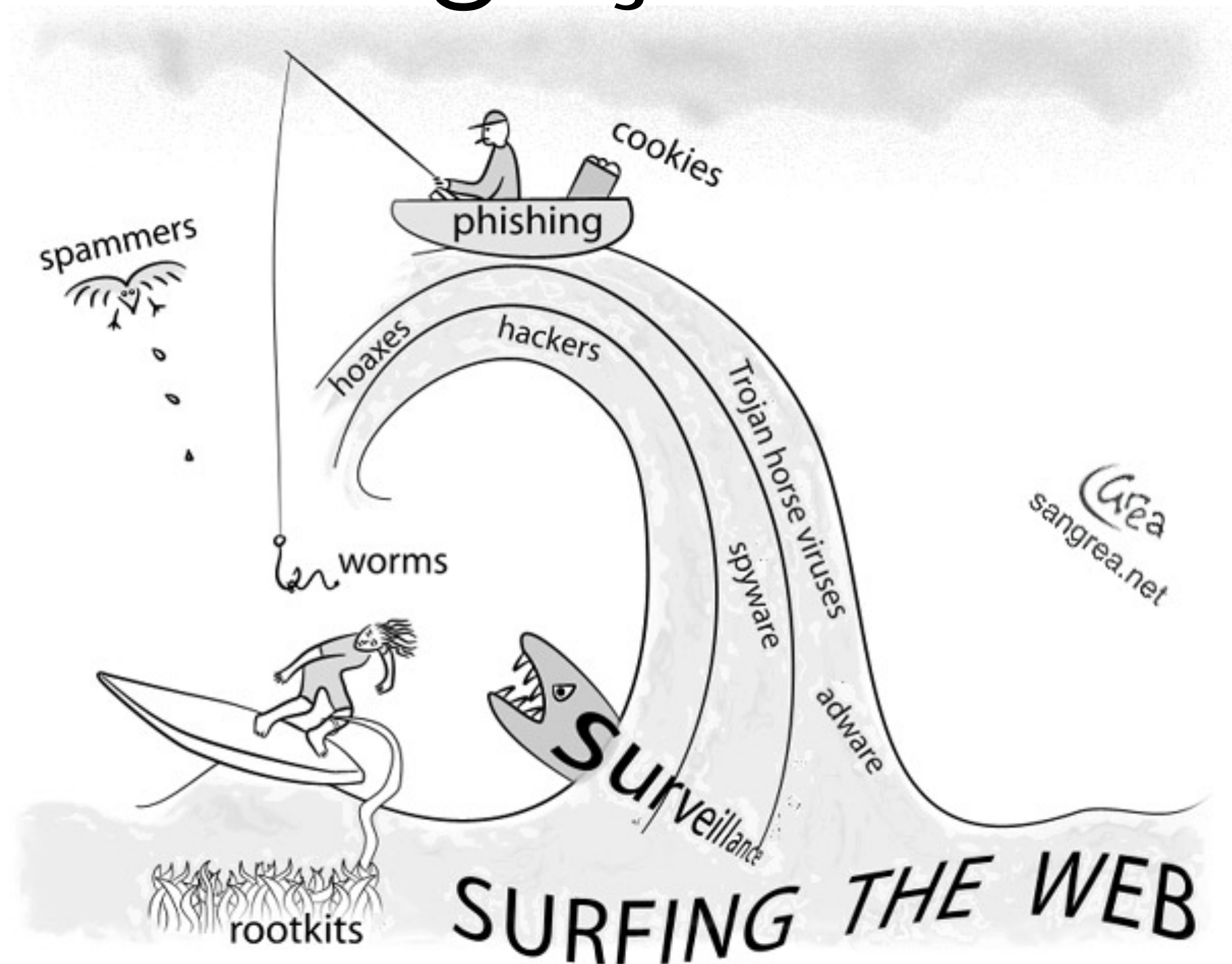


- *the process of converting information or data into a code, especially to prevent unauthorized access*
(Oxford English Dictionary)
- Dois tipos principais de sistemas de encriptação:
 - Chave simétrica (uma só chave)
 - Chave assimétrica (chave pública + chave privada)
- São considerados dados pessoais?

Riscos para a Privacidade de Dados Pessoais

- De acordo com “A Taxonomy of Privacy”, Daniel Solove, 2006:
 - Agregação: juntar informação sobre uma pessoa
 - Identificação: associar dados a um indivíduo em particular
 - Insegurança: problemas na manipulação da informação
 - Exclusão: não fornecer aos indivíduos notificações sobre a sua informação
 - Divulgação: quando informação de uma pessoa é revelada a outras
 - Exposição: quando características físicas ou emocionais são reveladas a outros
 - Intrusão: invasão do espaço digital, e.g. spam

Navegação Web



Privacidade da Informação: Ameaças

- Navegação Web (informação circula em ambas as direcções)
- Browsers sabem muito sobre os utilizadores (<https://webkay.robinlinus.com/>)
- Concentração de informação nas entidades (empresas) que disponibilizam serviços na internet
- Enorme capacidade de armazenamento/cálculo disponibilizado pela tecnologia actual
- Suporte digital na generalidade das fontes de informação

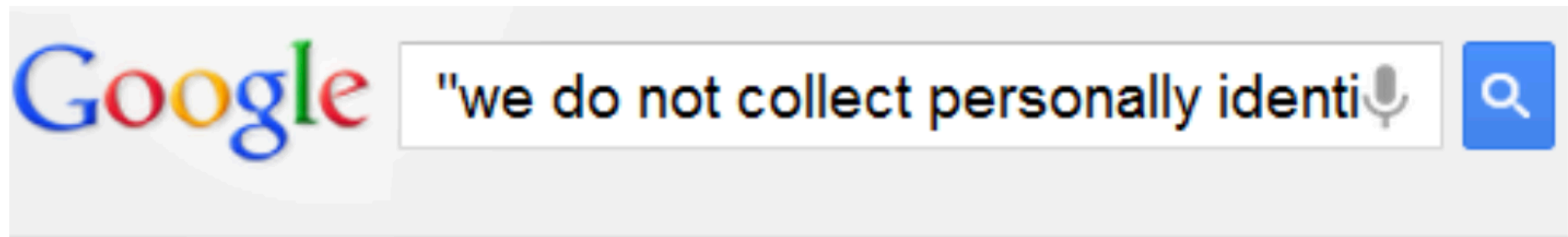
Gostos e Compras



Redes Sociais



Se eles dizem



Search

About 72,900,000 results (0.24 seconds)



A race to the bottom: um estudo sobre as práticas de privacidade das principais companhias de serviços na internet

- Estudo conduzido em 2007 pela “Privacy International”
- Incluiu as principais operadoras: Amazon, AOL, Apple, BBC, eBay, Facebook, Google, LinkedIn, LiveJournal, Microsoft, MySpace, Skype, Wikipedia, LiveSpace, Yahoo!, YouTube
- Âmbito:

Aquisição e processamento da informação

Retenção da informação

Abertura e transparências das práticas

Controlo dos clientes/utilizadores

Inovações promotoras/comprometedoras da privacidade

e.g. Google

Privacy-friendly and privacy enhancing

Generally privacy-aware but in need of improvement

Generally aware of privacy rights, but demonstrate some notable lapses

Serious lapses in privacy practices

Substantial and comprehensive privacy threats

Comprehensive consumer surveillance & entrenched hostility to privacy

[illegible]

№ п/п	Наименование объекта	Адрес	Вид собственности	Вид объекта	Площадь	Стоимость	Срок	Состояние	Содержание	Содержание	Содержание	Содержание
1	Объект недвижимости	г. Москва, м. Ховрино, ул. Мухоморова, д. 10	Чужая	Земельный участок	100 кв. м	1000000 руб.	10 лет	Средний	Содержание	Содержание	Содержание	Содержание
2	Объект недвижимости	г. Москва, м. Ховрино, ул. Мухоморова, д. 10	Чужая	Земельный участок	100 кв. м	1000000 руб.	10 лет	Средний	Содержание	Содержание	Содержание	Содержание
3	Объект недвижимости	г. Москва, м. Ховрино, ул. Мухоморова, д. 10	Чужая	Земельный участок	100 кв. м	1000000 руб.	10 лет	Средний	Содержание	Содержание	Содержание	Содержание

	1. PROJEKTIN NÁZEV	2. PROJEKTUJÍCÍ ÚSTAV	3. PROJEKTANT	4. PROJEKTOVÝ ZÁKAZNÍK	5. PROJEKTOVÝ ZÁKAZNÍK	6. PROJEKTOVÝ ZÁKAZNÍK	7. PROJEKTOVÝ ZÁKAZNÍK	8. PROJEKTOVÝ ZÁKAZNÍK	9. PROJEKTOVÝ ZÁKAZNÍK	10. PROJEKTOVÝ ZÁKAZNÍK	11. PROJEKTOVÝ ZÁKAZNÍK	12. PROJEKTOVÝ ZÁKAZNÍK
PROJEKTANT	1. PROJEKTANT	2. PROJEKTANT	3. PROJEKTANT	4. PROJEKTANT	5. PROJEKTANT	6. PROJEKTANT	7. PROJEKTANT	8. PROJEKTANT	9. PROJEKTANT	10. PROJEKTANT	11. PROJEKTANT	12. PROJEKTANT
PROJEKTOVÝ ZÁKAZNÍK	1. PROJEKTOVÝ ZÁKAZNÍK	2. PROJEKTOVÝ ZÁKAZNÍK	3. PROJEKTOVÝ ZÁKAZNÍK	4. PROJEKTOVÝ ZÁKAZNÍK	5. PROJEKTOVÝ ZÁKAZNÍK	6. PROJEKTOVÝ ZÁKAZNÍK	7. PROJEKTOVÝ ZÁKAZNÍK	8. PROJEKTOVÝ ZÁKAZNÍK	9. PROJEKTOVÝ ZÁKAZNÍK	10. PROJEKTOVÝ ZÁKAZNÍK	11. PROJEKTOVÝ ZÁKAZNÍK	12. PROJEKTOVÝ ZÁKAZNÍK
PROJEKTOVÝ ZÁKAZNÍK	1. PROJEKTOVÝ ZÁKAZNÍK	2. PROJEKTOVÝ ZÁKAZNÍK	3. PROJEKTOVÝ ZÁKAZNÍK	4. PROJEKTOVÝ ZÁKAZNÍK	5. PROJEKTOVÝ ZÁKAZNÍK	6. PROJEKTOVÝ ZÁKAZNÍK	7. PROJEKTOVÝ ZÁKAZNÍK	8. PROJEKTOVÝ ZÁKAZNÍK	9. PROJEKTOVÝ ZÁKAZNÍK	10. PROJEKTOVÝ ZÁKAZNÍK	11. PROJEKTOVÝ ZÁKAZNÍK	12. PROJEKTOVÝ ZÁKAZNÍK
PROJEKTOVÝ ZÁKAZNÍK	1. PROJEKTOVÝ ZÁKAZNÍK	2. PROJEKTOVÝ ZÁKAZNÍK	3. PROJEKTOVÝ ZÁKAZNÍK	4. PROJEKTOVÝ ZÁKAZNÍK	5. PROJEKTOVÝ ZÁKAZNÍK	6. PROJEKTOVÝ ZÁKAZNÍK	7. PROJEKTOVÝ ZÁKAZNÍK	8. PROJEKTOVÝ ZÁKAZNÍK	9. PROJEKTOVÝ ZÁKAZNÍK	10. PROJEKTOVÝ ZÁKAZNÍK	11. PROJEKTOVÝ ZÁKAZNÍK	12. PROJEKTOVÝ ZÁKAZNÍK

1	1.1	1.1.1	1.1.1.1	1.1.1.2	1.1.1.3	1.1.1.4	1.1.1.5	1.1.1.6	1.1.1.7	1.1.1.8	1.1.1.9	1.1.1.10	1.1.1.11	1.1.1.12	1.1.1.13	1.1.1.14	1.1.1.15	1.1.1.16	1.1.1.17	1.1.1.18	1.1.1.19	1.1.1.20	1.1.1.21	1.1.1.22	1.1.1.23	1.1.1.24	1.1.1.25	1.1.1.26	1.1.1.27	1.1.1.28	1.1.1.29	1.1.1.30	1.1.1.31	1.1.1.32	1.1.1.33	1.1.1.34	1.1.1.35	1.1.1.36	1.1.1.37	1.1.1.38	1.1.1.39	1.1.1.40	1.1.1.41	1.1.1.42	1.1.1.43	1.1.1.44	1.1.1.45	1.1.1.46	1.1.1.47	1.1.1.48	1.1.1.49	1.1.1.50	1.1.1.51	1.1.1.52	1.1.1.53	1.1.1.54	1.1.1.55	1.1.1.56	1.1.1.57	1.1.1.58	1.1.1.59	1.1.1.60	1.1.1.61	1.1.1.62	1.1.1.63	1.1.1.64	1.1.1.65	1.1.1.66	1.1.1.67	1.1.1.68	1.1.1.69	1.1.1.70	1.1.1.71	1.1.1.72	1.1.1.73	1.1.1.74	1.1.1.75	1.1.1.76	1.1.1.77	1.1.1.78	1.1.1.79	1.1.1.80	1.1.1.81	1.1.1.82	1.1.1.83	1.1.1.84	1.1.1.85	1.1.1.86	1.1.1.87	1.1.1.88	1.1.1.89	1.1.1.90	1.1.1.91	1.1.1.92	1.1.1.93	1.1.1.94	1.1.1.95	1.1.1.96	1.1.1.97	1.1.1.98	1.1.1.99	1.1.1.100
2	2.1	2.1.1	2.1.1.1	2.1.1.2	2.1.1.3	2.1.1.4	2.1.1.5	2.1.1.6	2.1.1.7	2.1.1.8	2.1.1.9	2.1.1.10	2.1.1.11	2.1.1.12	2.1.1.13	2.1.1.14	2.1.1.15	2.1.1.16	2.1.1.17	2.1.1.18	2.1.1.19	2.1.1.20	2.1.1.21	2.1.1.22	2.1.1.23	2.1.1.24	2.1.1.25	2.1.1.26	2.1.1.27	2.1.1.28	2.1.1.29	2.1.1.30	2.1.1.31	2.1.1.32	2.1.1.33	2.1.1.34	2.1.1.35	2.1.1.36	2.1.1.37	2.1.1.38	2.1.1.39	2.1.1.40	2.1.1.41	2.1.1.42	2.1.1.43	2.1.1.44	2.1.1.45	2.1.1.46	2.1.1.47	2.1.1.48	2.1.1.49	2.1.1.50	2.1.1.51	2.1.1.52	2.1.1.53	2.1.1.54	2.1.1.55	2.1.1.56	2.1.1.57	2.1.1.58	2.1.1.59	2.1.1.60	2.1.1.61	2.1.1.62	2.1.1.63	2.1.1.64	2.1.1.65	2.1.1.66	2.1.1.67	2.1.1.68	2.1.1.69	2.1.1.70	2.1.1.71	2.1.1.72	2.1.1.73	2.1.1.74	2.1.1.75	2.1.1.76	2.1.1.77	2.1.1.78	2.1.1.79	2.1.1.80	2.1.1.81	2.1.1.82	2.1.1.83	2.1.1.84	2.1.1.85	2.1.1.86	2.1.1.87	2.1.1.88	2.1.1.89	2.1.1.90	2.1.1.91	2.1.1.92	2.1.1.93	2.1.1.94	2.1.1.95	2.1.1.96	2.1.1.97	2.1.1.98	2.1.1.99	2.1.1.100
3	3.1	3.1.1	3.1.1.1	3.1.1.2	3.1.1.3	3.1.1.4	3.1.1.5	3.1.1.6	3.1.1.7	3.1.1.8	3.1.1.9	3.1.1.10	3.1.1.11	3.1.1.12	3.1.1.13	3.1.1.14	3.1.1.15	3.1.1.16	3.1.1.17	3.1.1.18	3.1.1.19	3.1.1.20	3.1.1.21	3.1.1.22	3.1.1.23	3.1.1.24	3.1.1.25	3.1.1.26	3.1.1.27	3.1.1.28	3.1.1.29	3.1.1.30	3.1.1.31	3.1.1.32	3.1.1.33	3.1.1.34	3.1.1.35	3.1.1.36	3.1.1.37	3.1.1.38	3.1.1.39	3.1.1.40	3.1.1.41	3.1.1.42	3.1.1.43	3.1.1.44	3.1.1.45	3.1.1.46	3.1.1.47	3.1.1.48	3.1.1.49	3.1.1.50	3.1.1.51	3.1.1.52	3.1.1.53	3.1.1.54	3.1.1.55	3.1.1.56	3.1.1.57	3.1.1.58	3.1.1.59	3.1.1.60	3.1.1.61	3.1.1.62	3.1.1.63	3.1.1.64	3.1.1.65	3.1.1.66	3.1.1.67	3.1.1.68	3.1.1.69	3.1.1.70	3.1.1.71	3.1.1.72	3.1.1.73	3.1.1.74	3.1.1.75	3.1.1.76	3.1.1.77	3.1.1.78	3.1.1.79	3.1.1.80	3.1.1.81	3.1.1.82	3.1.1.83	3.1.1.84	3.1.1.85	3.1.1.86	3.1.1.87													

[illegible][illegible]

Principais críticas às práticas da Google

- Armazena uma quantidade imensa de informação sobre os utilizadores, sem prazos estabelecidos nem uma limitação apropriada do seu uso ou política de divulgação
- Registo das frases pesquisadas e dos respectivos IP e timestamps são mantidos por, pelo menos, 18/24 meses
- Cruza informação com perfis de utilizador (e.g. Orkut)
- Utilização de técnicas avançadas de classificação para publicidade dirigida

e.g. Amazon

- O sistema de recomendações da Amazon sugere artigos com base na experiência de “clientes similares”.
- No entanto, esse mecanismo pode constituir uma falha grave na privacidade dos clientes:
“If I knew five or six things you bought on Amazon, I could buy those same things, and all of a sudden, we’re now the two most similar customers in Amazon’s recommendation algorithm. I could then start seeing what else you were buying, as whatever you bought would then be recommended to me.”
- Obs: a Amazon permite agora um maior controle do utilizador nas recomendações que lhe são apresentadas (e.g. permitindo excluir artigos, adicionar novos ou limpar as suas preferências...)

Um caso PT: Nónio

- plataforma tecnológica criada pelos maiores grupos de comunicação do país (criada em 2017)
- sistema de registo único entre grupos de media
- ameaças:
 - armazena todo o histórico de artigos lidos pelo utilizador nos websites aderentes (IP, data acesso, localização, etc) e permite a sua utilização por terceiros
 - só remove/anonimiza dados um ano após apagadas as contas
 - apresenta notícias direcionadas consoante as preferências dos leitores
- Campanha Anti Nónio (<https://nonio.pt/>)
- Obs: O Público abandonou o Nónio em finais de 2019

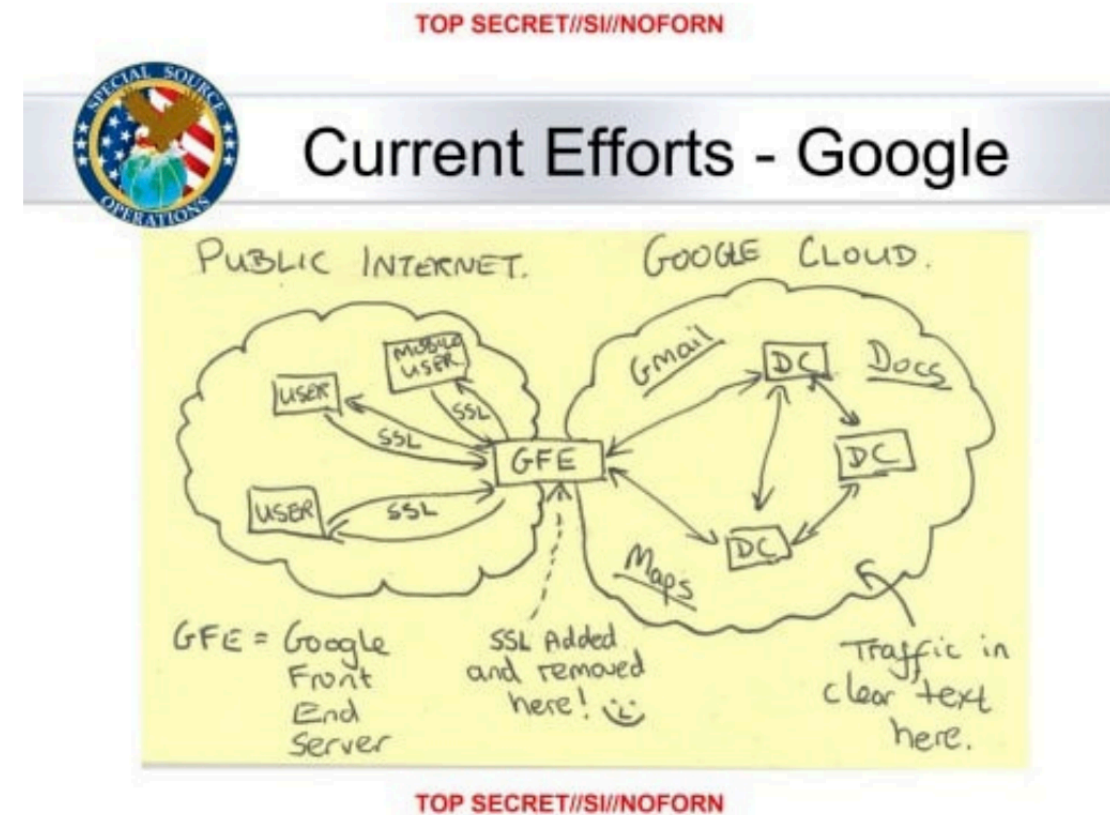
Diabolização do Google/Facebook/etc.?

- Modelo de negócio assenta claramente em:
 - publicidade dirigida
 - cruzar e vender dados dos utilizadores
 - personalizar experiência de utilização (<http://dontbubble.us>)



Vigilância de massas

- *Even if you're not doing anything wrong, you're being watched and recorded.*
(Edward Snowden)
- (Alguns) governos têm enormes recursos e a capacidade de instalar “backdoors”
- Muitos exemplos...



Edward Snowden ✓ @Snowden · Oct 4, 2016

Use [@Yahoo](#)? They secretly scanned everything you ever wrote, far beyond what law requires. Close your account today.

Muitas outras Ameaças

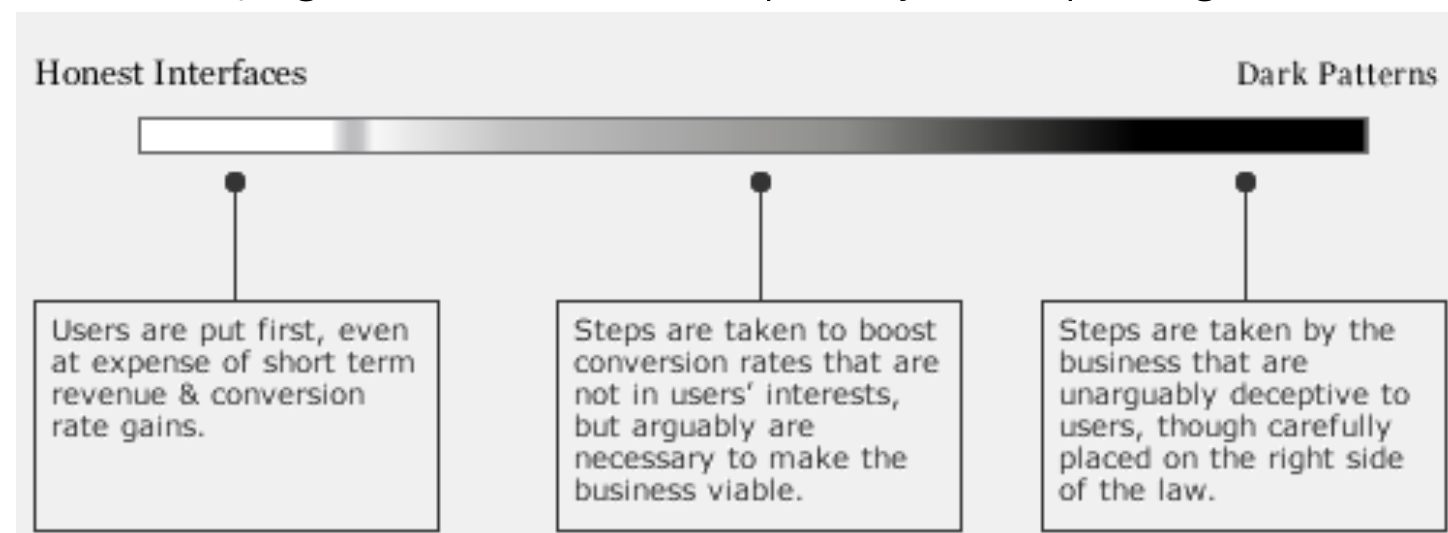
- Roubo de identidade digital (e.g. hacker enganou bancos e roubou milhões de dólares a famosos como Steven Spielberg ou Warren Buffet, 2001)
- “Phishing” (e.g., hackers cobraram pagamentos com aspecto genuíno a clientes do Booking.com, 2018)
- Fugas de dados (mesmo depois de “apagados”) (e.g. caso Ashley Madison, 2015; caso Cambridge Analytica, 2018)
- “Pesquisa perigosa” (e.g. motor de busca Yandex com links para Google Docs “privados”, 2018)
- ...

Protecção de Privacidade

- Enquadramento legal
 - **legislação de âmbito alargado** (e.g. directiva protecção dados EU)
 - legislação sectorial (e.g. área médica US HIPAA)
- Auto-regulação
 - Códigos de práticas estabelecidos por companhias ou consórcios
- **Tecnologia para a privacidade**
 - técnicas (criptográficas, ou outras) concebidas para permitir o processamento da informação protegendo adequadamente o acesso aos dados pessoais

Nas entrelinhas da Proteção de Privacidade: Padrões Negros

- Mesmo que cumpram todas as normas legais e técnicas, empresas podem sempre recorrer a truques menos éticos, os chamados *dark patterns* (<https://uxdesign.cc>). Por exemplo:
- Manipulação temporal (vencer por cansaço)
- Difícil saltar fora (e.g. Facebook para associar contas com WhatsApp em 2016)
- Exemplos tendenciosos (e.g. Facebook para convencer utilizadores EU a aceitar tecnologia de reconhecimento facial)
- Fricção (e.g. Público nos seus cookies tinha uma longa lista de empresas parceiras, uma opção para seleccionar todas, e nenhuma para desseleccionar)
- Manipulação emocional (e.g. Facebook dizer que “ajuda a proteger contra estranhos”)



GDPR

- General Data Protection Regulation 2016/679
- Objetivos:
 - Proteger dados pessoais e enriquecer direitos de privacidade de cidadãos EU
 - Dar aos utilizadores maior controlo sobre os seus dados
- Afecta:
 - Todas as empresas que manipulem dados de cidadãos EU

GDPR: Direitos



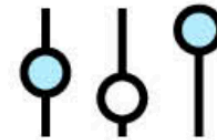
The Right to Be Informed

Individuals have a right to know who is processing their personal data



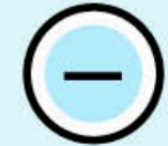
The Right to Access

Individuals have the right to access any personal data that has been collected about them



The Right to Rectifications

Individuals have the right to require organizations to correct inaccurate personal data



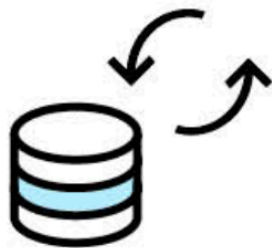
The Right to Be Forgotten

Individuals have the right to have their personal data deleted and to prevent further collection



The Right to Restrict Processing

Individuals have the right to require organizations to restrict the processing of specific categories of personal data



The Right to Data Portability

Individuals have the right to require organizations to transfer personal data to a recipient of their choice



The Right to Object

Individuals have the right to consent, or withdraw consent, to the processing of their personal data



Rights in Relation to Automated Decision Making and Profiling

Individuals have the right to opt out of the use of their personal data by automated systems, such as artificial intelligence

GDPR: Princípios

- Consent: processamento de dados pessoais é proibido, a menos que especialmente permitido por lei ou o sujeito dê consentimento
- Lawfulness: processamento de dados pessoais deve ser de acordo com a lei, justo e transparente
- Purpose limitation: só se pode recolher dados pessoais para fins específicos, explícitos, legítimos
- Data minimisation: só se deve processar a informação adequada e relevante
- Accuracy: Dados processados devem ser exatos e atualizados
- Storage limitation: só se pode manter dados pessoais enquanto servirem o propósito
- Integrity and confidentiality: garantir que o processamento de dados é bem protegido
- **Accountability**: controlador dos dados tem que demonstrar que está conforme os regulamentos

GDPR: Privacy/Data Protection Impact Assessment (PIA)

- *the controller shall, prior to the processing, carry out an assessment of the impact of the envisaged processing operations on the protection of personal data*
(Art 35° GDPR)
- Deve incluir pelo menos:
 1. *a systematic description of the envisaged processing operations and the purposes of the processing*
 2. *an assessment of the necessity and proportionality of the processing operations*
 3. *an assessment of the risks to the rights and freedoms of data subjects*
 4. *the measures envisaged to address the risks, including safeguards, security measures and mechanisms to ensure the protection of personal data and to demonstrate compliance*
- Em muitos casos, deve nomear um Data Protection Officer (DPO)

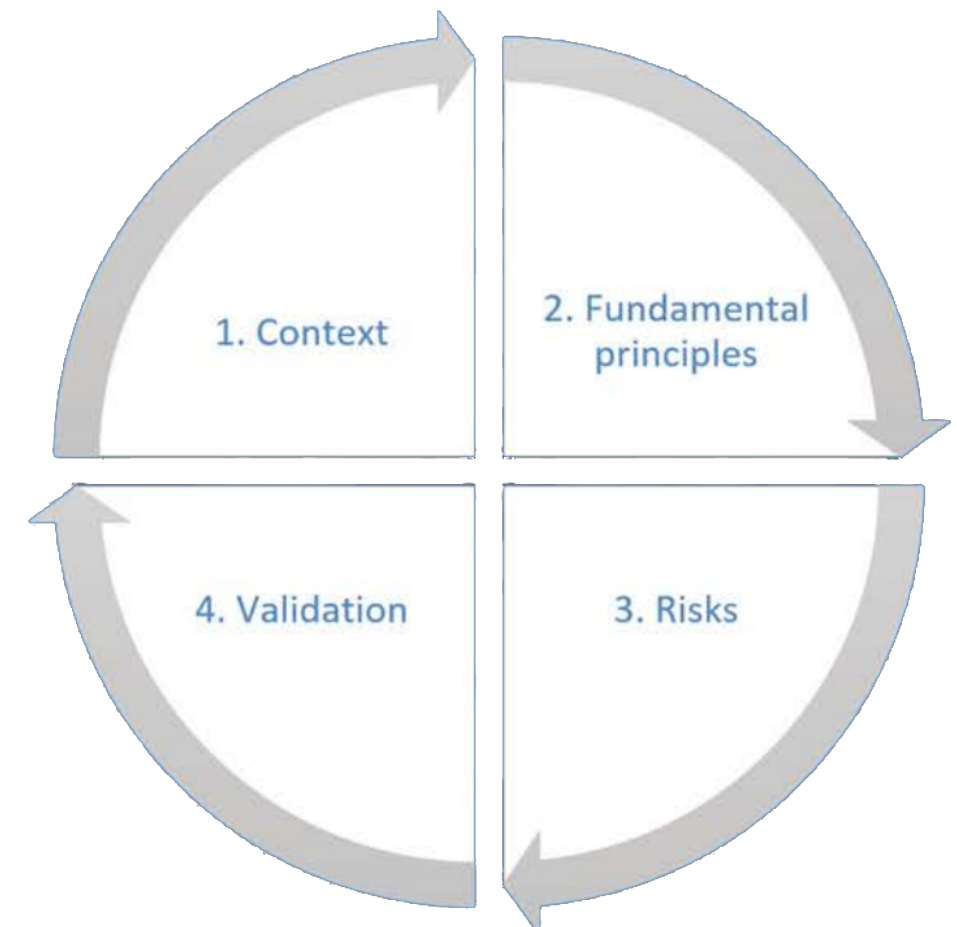
Da perspectiva das empresas



Uma metodologia PIA

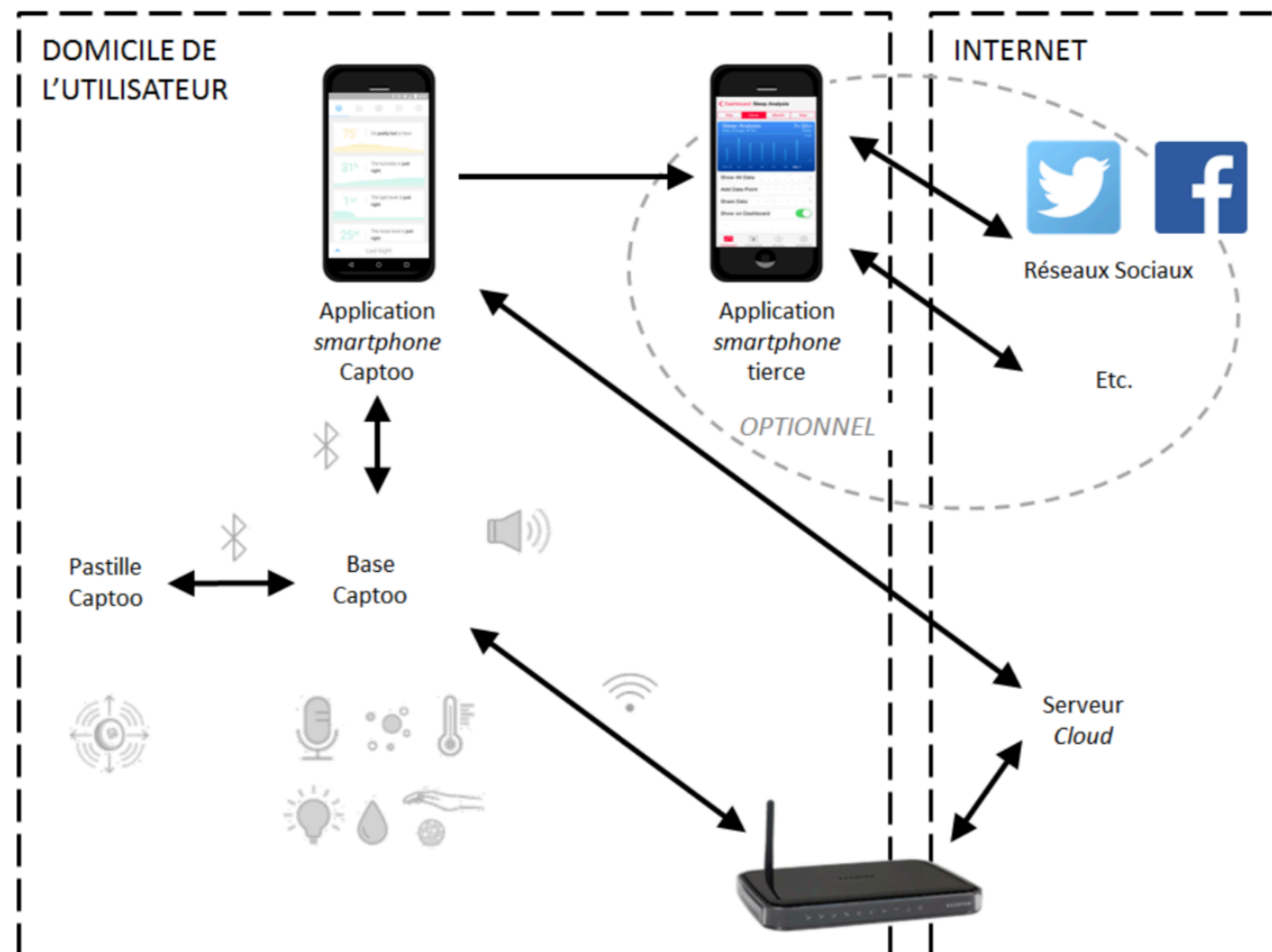


- Proposta pela CNIL (<https://cnil.fr>)
 - Um processo contínuo
 - “Privacy/Data Protection by Design”, antes de processar dados pessoais
1. Descrever o processamento de dados pessoais
 2. Argumentar como o sistema está em conformidade com a legislação
 3. Conhecer os garantes de segurança e das causas e consequências de riscos associados
 4. Aceitar ou não (por parte do DPO)
- Software: <https://www.cnil.fr/en/open-source-pia-software-helps-carry-out-data-protection-impact-assessment>



Caso de Estudo (Captoo)

- Descrição: Aplicação móvel que utiliza diferentes sensores do telemóvel durante a noite para conhecer e compreender o ambiente do utilizador.
- Objetivos: Medir padrões de sono do utilizador, e melhorar a qualidade do seu sono.
- Download: <https://www.di.uminho.pt/~hpacheco/mdi/captoo.json>



Caso de Estudo (IoT)

- Descrição: Um brinquedo com microfone, câmara e botões de ligar, desligar e ação. Liga-se por rede a uma aplicação móvel num telemóvel ou tablet, ou a um serviço online.
- Objetivos: Interagir com uma criança, através de um diálogo em linguagem natural utilizando processamento de voz. Permitir à criança comunicar online (por voz, mensagens, fotos) com os seus amigos. Fornecer informação de monitorização aos pais.

